

Studio degli IoC

Report Analisi Malware:

1. Introduzione e Scopo del Progetto

Il presente documento espone l'analisi tecnica di un file potenzialmente dannoso eseguito tramite la piattaforma **ANY.RUN**, questo strumento di analisi malware ci permette di eseguire file sospetti in un ambiente isolato (**sandbox**) per osservarne il comportamento in tempo reale senza infettare la propria rete.

2. Descrizione Generale

Appena si accede alla pagina dell'analisi, l'interfaccia mostra un ambiente Windows 10 in esecuzione.

I primi elementi critici rilevati sono:

- Il file viene scaricato direttamente da un repository pubblico di **GitHub** (github.com/MELITERER/...), una tecnica usata per eludere i filtri di rete che solitamente si fidano del traffico verso GitHub.
- All'esecuzione del file (**Muadnrd.exe** o **Jvczfhe.exe**), l'utente vede un falso messaggio di errore: *"There was an error opening this document. The file is damaged"*. Questo serve a far credere alla vittima che l'applicazione sia fallita, mentre il malware lavora silenziosamente in background.
- Il malware non appare con il suo vero nome nel sistema, ma si camuffa utilizzando nomi di processi legittimi come **firefox.exe** e **Microsoft Edge**.

3. Analisi degli Indicatori e dei Processi (.exe)

Durante l'analisi, abbiamo osservato diversi file eseguibili `.exe` e quadranti colorati in arancioni e verdi.

- **Arancione (Suspicious):** Indica attività che non sono normali per un programma standard (es. *scrivere in cartelle di sistema o leggere registri sensibili*).
- **Verde (Clean/Informational):** Operazioni comuni del sistema operativo.
- **Jvczfhe.exe / Muadnrd.exe:** Sono i "Dropper" o "Loader" iniziali. Il loro compito è entrare nel sistema e scaricare o avviare i payload.
- **InstallUtil.exe:** Un programma legittimo di Windows .NET che il malware abusa per eseguire codice senza sollevare sospetti.

4. Analisi dei Warning e dei Punteggi

Di seguito vengono elencati dei processi analizzati, con i relativi punteggi di pericolosità e le tecniche rilevate:

A. Processo Firefox.exe (ID 6596) – Punteggio: 94/100 (Malicious)



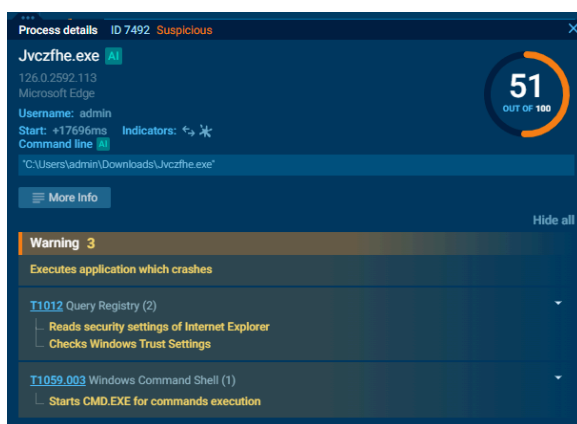
Nonostante il nome, il punteggio quasi massimo indica un'attività chiaramente malevola.

- **T1036.003 (Masquerading)**: Il malware rinomina se stesso come "Firefox" per nascondersi tra i processi aperti.
- **Attività rilevata**: Iniezione di codice e connessioni di rete anomale per l'invio di dati (Exfiltration).

B. Muadnrd.exe (PID 7824) – Punteggio: 62/100 (Suspicious)

- **T1543.003 (Persistence)**: Il malware ha la capacità di auto-eseguirsi ("Application launched itself"). Questa tecnica serve a garantire che il codice rimanga attivo nel sistema anche dopo un tentativo di chiusura o riavvio.
- **Attività rilevata**: Esecuzione di un'applicazione che forza un errore o un crash ("Executes application which crashes"). Questa è una tattica di distrazione per far credere all'utente che il file sia corrotto, mentre il malware continua a operare in background.

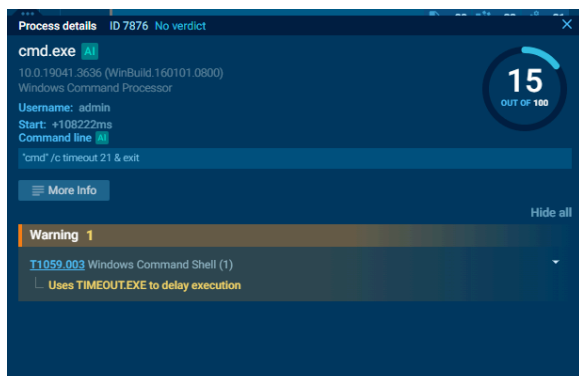
C. Processo Jvczfhe.exe (ID 7492) – Punteggio: 51/100 (Suspicious)



- **T1012 (Query Registry)**: Il malware interroga il registro di sistema per leggere le impostazioni di sicurezza di Internet Explorer e Windows Trust. Sta cercando di capire quanto è protetto il PC.

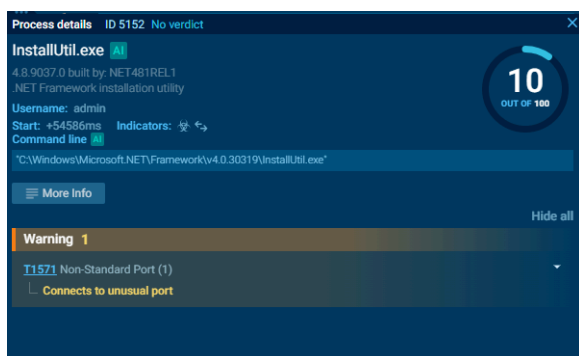
- **T1059.003 (Command Shell):** Avvia `cmd.exe` per eseguire comandi nascosti nel sistema.

D. Processo `cmd.exe` (ID 7876) – Punteggio: 15/100



- **T1059.003 (Delay Execution):** Esegue il comando `timeout 21`. Serve a mettere il malware in "pausa" per 21 secondi, sperando che i sistemi di scansione automatica smettano di monitorarlo prima che inizi a rubare dati.

E. Processo `InstallUtil.exe` (ID 5152) – Punteggio: 10/100



- **T1571 (Non-Standard Port):** Utilizza una porta di rete non comune per comunicare con l'esterno, cercando di bypassare i Firewall aziendali.

G. `Muadnrd.exe` (PID 7248) – Punteggio: 0/100 (Evasione e Ricognizione)

Nonostante il punteggio di base sia basso, questo processo è fondamentale per la fase di preparazione dell'attacco,

utilizzando tecniche silenziose per mappare il sistema vittima.



- **T1012 (Query Registry):** Il malware interroga il registro di sistema per raccogliere dati identificativi univoci.
 - **Attività rilevata:** Lettura del **Machine GUID** dal registro, acquisizione del **nome del computer** e verifica delle **lingue supportate** dal sistema.
- **T1082 (System Information Discovery):** Questa tecnica viene utilizzata per identificare l'ambiente in cui il malware è in esecuzione.
 - **Attività rilevata:** Raccolta di informazioni dettagliate sull'hardware e sulla configurazione software per confermare se il sistema è una vittima reale o un ambiente di analisi (Sandbox).
- **Protezione .NET Reactor:** È stata rilevata la presenza del protector **.NET Reactor**.
 - **Attività rilevata:** Uso di tecniche di offuscamento avanzate per rendere il codice illeggibile agli analisti, nascondendo le reali intenzioni del file eseguibile.

5. Analisi dei Dettagli di Rete (HTTP Requests)

HTTP Requests		31	Connections	99	DNS Requests	161	Network Threats	19	Hide whitelisted		Filter by PID, name or url	PCAP
Timeshift	Headers	Rep	PID	Process name	CN	URL	Content					
3675 ms	H1 GET 200: OK	✓	6596	firefox.exe	🇺🇸	http://detectportal.firefox.com/canonical.html	90 b ↓ text					
3729 ms	H1 GET 200: OK	✓	6596	firefox.exe	🇺🇸	http://detectportal.firefox.com/success.txt?pv4	8 b ↓ text					
3812 ms	H1 POST 200: OK	?	6596	firefox.exe	🇺🇸	http://ocsp.sectigo.com/	83 b ↑ binary 282 b ↓ binary					
3813 ms	H1 POST 200: OK	?	6596	firefox.exe	🇩🇪	http://r11.o.lencr.org/	85 b ↑ binary 504 b ↓ binary					
3877 ms	H1 POST 200: OK	?	6596	firefox.exe	🇩🇪	http://r11.o.lencr.org/	85 b ↑ binary 504 b ↓ binary					

Request details

Here are the details of your request

Request

Url: /

Protocol: HTTP/1.1

Method: POST

Host: ocsp.sectigo.com

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:123.0) Gecko/20100101 Firefox/123.0

Accept: */*

Accept-Language: en-US,en;q=0.5

Accept-Encoding: gzip, deflate

Content-Type: application/ocsp-request

Content-Length: 83

Connection: keep-alive

Pragma: no-cache

Cache-Control: no-cache

Response

Status code: 200: OK

Date: Sun, 25 Aug 2024 20:39:07 GMT

Content-Type: application/ocsp-response

Content-Length: 282

Connection: keep-alive

Last-Modified: Fri, 23 Aug 2024 04:49:45 GMT

Queste schermate mostrano cosa succede dietro mentre il malware è in esecuzione:

- **Metodo POST e Esfiltrazione:** Le immagini evidenziano diverse richieste con metodo **POST** effettuate dal processo **firefox.exe** (PID 6596). A differenza del metodo **GET** (usato per scaricare), il **POST** viene utilizzato qui per **inviare dati** dal computer della vittima verso l'esterno.
- **Destinazioni e Geolocalizzazione:**
 - Si osservano connessioni verso domini come **ocsp.sectigo.com** (Stati Uniti) e **r11.o.lencr.org** (Germania).
 - Sebbene questi domini siano legati a servizi di certificati di sicurezza, il malware li usa spesso per nascondere il proprio traffico (**tunneling**) o per verificare la connettività senza destare sospetti.
- **Request Details:**

- **User-Agent:** Il malware si presenta con una stringa identificativa di Firefox 123.0 su Windows 10 (`Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:123.0)...`). Questo serve a far sembrare il traffico generato da un normale browser.
- **Content-Type:** La richiesta è di tipo `application/ocsp-request` , un formato tecnico che serve a mascherare i dati rubati all'interno di normali verifiche di sicurezza dei siti web.
- **Response Details:**
 - Il server risponde con un codice **200 OK**, confermando che i dati inviati dal malware sono stati ricevuti correttamente dal server di destinazione.
 - Viene indicato l'uso di **Cloudflare** come server, una tecnica comune per nascondere l'indirizzo IP reale dei criminali dietro un servizio di protezione legittimo.

6. Spiegazione Generale del Comportamento

Il malware analizzato segue una catena di infezione complessa:

1. **Ingresso:** Sfrutta GitHub come host affidabile.
2. **Evasione:** Utilizza l'ofuscamento (.NET Reactor) e il comando `timeout` per non essere rilevato.
3. **Persistenza e Iniezione:** Si inietta in `firefox.exe` per agire indisturbato.
4. **Ricognizione:** Legge le chiavi di registro di Office e del sistema per raccogliere informazioni sulla vittima.
5. **Comunicazione (C2):** Effettua richieste **HTTP POST** verso server in Germania e USA, camuffando il traffico come richieste di certificati di sicurezza.

7. Conclusione

In conclusione, l'analisi degli IoC rivela una minaccia di tipo **InfoStealer/Trojan** altamente evasiva. L'elevato punteggio di **94/100** su alcuni processi conferma che non si tratta di un errore software, ma di un attacco deliberato. Il malware combina l'uso di strumenti legittimi del sistema operativo con tecniche di camuffamento grafico per ingannare l'utente finale. Si raccomanda di bloccare gli hash dei file analizzati e monitorare le comunicazioni verso i domini sospetti rilevati nella sezione network.